# Roll Transparency Log · מסמך אפיון: Case 03

לפי פרק 2 (אפיון) בתבנית תיק הפרויקט של מגשימים: מה המוצר מבטיח, הפיצ'רים לפי שכבות, לכל פיצ'ר תיאור, שלבים, רשומה, קלט ופלט, איום ותשובה, הטכנולוגיות, ההחלטות, מה השתנה מה-*POC*, ומה נשאר פתוח. הדמויות בדויות.

## תרחיש פתיחה

ביום פרסום הטיוטה, פריה, אחות בלקנאו, גילתה מצילום מסך של חברה שהשם שלה לא בפנקס.

הסיבה: "נעדר, עבר או אחר". אף אחד לא התקשר. היא לא יודעת מי מחק, מתי, ואיפה.

והיא לא לבד: יותר מ-130 מיליון שמות יצאו מהטיוטות, והתהליך נוהל בתוכנה שלא מראה מי הוסר ולמה.

המערכת שנבנית כאן היא יומן שקוף (Roll Transparency Log): כל שינוי נרשם עם סיבה, אי אפשר לשנות אותו בשקט, וכל אדם בודק את עצמו.

בחלקים הבאים נבנה אותו מאפס, חלק אחרי חלק.

## מה המוצר מבטיח

- כל שינוי בפנקס, עם סיבה, נשמר כך שאי אפשר לשנות אותו בשקט.
- כל אדם בודק את השורה שלו בשנייה, ומקבל הוכחה.
- בלי שמות ביומן, ובלי לסמוך על מי שמריץ אותו.

## מבנה המוצר: ארבע שכבות

| שכבה | הפיצ'רים |
|---|---|
| בכניסה | 1. קליטת שינויים, 2. קודי סיבה מפורטים, 3. מזהים מוצפנים |
| היומן | 4. יומן מרקל, 5. ראשי עץ חתומים, 6. התאמת פנקס ליומן |
| אצל הבוחר | 7. בדיקה עצמית, 8. התראה ופתיחת ערעור |
| המשגיחים | 9. רשת משגיחים, 10. נתונים מצרפיים |

## שלב 1: בכניסה

מה נכנס ליומן, ובאיזו צורה. הכול מתחיל במערכת הקיימת. שלושה חלקים: קליטה שקוראת כל שינוי ישר מהמסד, קודי סיבה שמפרקים את הסל, ומזהים מוצפנים שמוציאים את השמות.

### פיצ'ר 1: קליטת שינויים

כל פעולה של קצין רישום נשלחת ליומן לפני שהיא נכנסת לתוקף.

כמו קופה רושמת: המוכר לא כותב קבלה בסוף היום מהזיכרון. כל מכירה נרשמת ברגע שהיא קורית, והגליל לא נגזר.

מה זה Change Data Capture **CDC?**: קריאה של כל שינוי שנכתב למסד הנתונים, ישר מהיומן הפנימי של המסד. התוכנה הקיימת לא צריכה לדעת שקוראים אותה.

איך זה עובד:

1. קצין רישום מסיר את פריה במערכת הקיימת, כמו היום.
2. Debezium קורא את השורה החדשה מטבלת השינויים.
3. השורה הופכת לאירוע ChangeEvent ונכנסת לתור, לפי מחוז.
4. שינוי שלא הגיע ליומן תוך 24 שעות מסומן "תלוי", ונראה בהתאמה.

נכנס: שורה במסד של הפנקס · יוצא: אירוע בתור, לפי מחוז

רשומה: `ChangeEvent`

| שדה | משמעות |
|---|---|
| `event_id` | מספר ייחודי לאירוע, נגד כפילות |
| `district / booth` | מחוז וקלפי |
| `action` | ADD, REMOVE, MOVE או RESTORE |
| `reason` | קוד סיבה מפיצ'ר 2 |
| `elector_ref` | מזהה מוצפן מפיצ'ר 3 |
| `effective` | תאריך כניסה לתוקף |

מה יכול להשתבש: מתכנת בוועדה כותב סקריפט שמוחק אלף שורות ישר במסד, "לניקוי". התשובה: הקריאה היא מהמסד עצמו, לא מהממשק. גם מחיקה ישירה נקראת.

טכנולוגיות: Debezium, Apache Kafka

## פיצ'ר 2: קודי סיבה מפורטים

כל מחיקה אומרת למה, מתוך רשימה סגורה של 11 קודים, עם ראיה.

כמו רופא שכותב אבחון: לא "לא מרגיש טוב", אלא שם המחלה ומה ראה בבדיקה. אחר כך כל רופא אחר יכול לבדוק אותו.

למה לפרק את הסל? "נעדר, עבר או אחר" מאחד שלוש תופעות. מי שלא היה בבית ביום הביקור, מי שבאמת עבר, וכל השאר. מבחוץ אי אפשר לדעת, ולכן אי אפשר לתקן.

איך זה עובד:

1. הקצין בוחר קוד מתוך 11: R-DEAD, R-DUP, R-SHIFT, R-ABSENT, R-NOFORM, R-REQ, R-COURT, A-NEW, A-RESTORE, M-MOVE, M-FIX.
2. לכל קוד שדה ראיה חובה: תעודת פטירה, מספר הרשומה הכפולה, כתובת חדשה, שלושה תאריכי ביקור.
3. הראיה עצמה לא נכנסת ליומן, רק הגיבוב שלה.
4. קוד בלי ראיה, או קוד שלא ברשימה, נדחה לפני שהוא יוצא.

נכנס: אירוע עם קוד וראיה · יוצא: אירוע מאושר, או דחייה

רשומה: `ReasonCode`

| שדה | משמעות |
|---|---|
| `code` | למשל R-ABSENT |
| `needs` | איזו ראיה חובה, למשל שלושה תאריכי ביקור |
| `appeal_days` | כמה ימים לערער |
| `shown_to_subject` | מוצג לבעל השורה |

מה יכול להשתבש: קצין ממשיך לרשום "אחר", כי ככה עשה עשרים שנה. התשובה: אין "אחר" ברשימה. הקוד לא עובר.

טכנולוגיות: רשימה סגורה של קודים, בדיקת ראיה

## פיצ'ר 3: מזהים מוצפנים

ביומן אין שמות ואין מספרים. כל בוחר וכל קצין מזוהים במפתח סודי.

כמו מספר תיק בבית חולים: הרופאים יודעים מי זה, הלוח במסדרון לא.

למה לא גיבוב רגיל? יש רק כמה מאות מיליוני מספרי בוחר אפשריים. מחשב רגיל מגבב את כולם בכמה שעות, ומקבל טבלה שממירה כל גיבוב בחזרה לאדם. עם מפתח סודי, הטבלה הזו לא אפשרית.

איך זה עובד:

1. מספר הבוחר נכנס לשירות שמחזיק HSM.
2. ה-HSM מחשב HMAC-SHA256 עם מפתח שלא יוצא ממנו אף פעם.
3. המזהה המוצפן נכנס לאירוע, והמספר הגלוי נזרק.
4. פעם בעונה המפתח מתחלף, והחלפה נרשמת ביומן.

נכנס: מספר בוחר גלוי · יוצא: מזהה מוצפן

רשומה: `ElectorRef`

| שדה | משמעות |
|---|---|
| `ref` | HMAC-SHA256(K_state, "elector" + מספר) |
| `key_epoch` | איזה מפתח, לפי עונה |
| `state` | מדינה |

מה יכול להשתבש: מישהו מוריד את כל היומן ומריץ עליו את כל מספרי הבוחר האפשריים. התשובה: בלי המפתח, הגיבוב לא ניתן לחישוב. המילון חסר ערך.

טכנולוגיות: HMAC-SHA256, HSM

## שלב 2: היומן

איך נשמר העבר, ומי מעיד עליו. הלב: עץ מרקל שרק גדל, ראש עץ חתום כל דקה, והתאמה שתופסת שינוי שלא נשלח.

## פיצ'ר 4: יומן מרקל

כל השורות נשמרות כעלים בעץ מרקל, ואי אפשר לשנות שורה ישנה בלי שזה יתגלה.

כמו ספר תורים בבית חולים שכתוב בעט ומדפיו ממוספרים ותפורים: אפשר להוסיף שורה בסוף, אי אפשר לקרוע דף.

מה זה עץ מרקל? כל שורה מגובבת. כל זוג גיבובים מגובב יחד, וכך הלאה, עד שנשאר גיבוב אחד: ראש העץ. שינוי באות אחת בשורה אחת משנה את ראש העץ.

איך זה עובד:

1. כל דקה נאספת אצווה של שינויים מהתור.
2. כל שינוי נכנס כעלה: גיבוב עם קידומת 0x00.
3. העץ נשמר כאריחים של 256 גיבובים, ומוגש מ-CDN.
4. שורה ישנה לא נכתבת מחדש אף פעם. תיקון הוא שורה חדשה, M-FIX.

נכנס: אצווה של אירועים · יוצא: עלים חדשים, ראש עץ חדש

רשומה: `LogEntry`

| שדה | משמעות |
|---|---|
| `index` | מספר השורה ביומן |
| `leaf` | SHA-256 של 0x00 ועוד האירוע |
| `tile` | האריח שבו העלה נמצא |

מה יכול להשתבש: מפעיל היומן משנה שורה ישנה מ-R-DEAD ל-R-DUP ומחשב מחדש את כל העץ. התשובה: ראש העץ החדש לא ממשיך את הישן. כל מי ששמר את הישן יודע. (נבדק ב-POC: התגלה.)

טכנולוגיות: Tessera, RFC 6962/9162, CDN

### פיצ'ר 5: ראשי עץ חתומים

כל דקה: גודל העץ וראש העץ, חתומים בידי הוועדה ואחר כך בידי המשגיחים.

כמו פרוטוקול של ישיבה: יו"ר חותם, ושני חברים חותמים אחריו. בלי שלוש החתימות, הפרוטוקול לא מאושר.

מה זה צ'קפוינט? שלוש שורות: שם היומן, גודל העץ, ראש העץ. ומתחתן חתימות. כל מי שמחזיק צ'קפוינט חתום יכול לבדוק כל הוכחה מולו.

איך זה עובד:

1. כותב היומן מפרסם צ'קפוינט חדש כל דקה.
2. הוועדה חותמת עליו ב-Ed25519, במפתח שיושב ב-HSM.
3. המשגיחים מושכים אותו, בודקים עקביות, ומוסיפים חתימה.
4. רק עם שלוש חתימות משגיחים הצ'קפוינט מוצג לבוחרים כ"מאומת".

נכנס: ראש עץ חדש · יוצא: צ'קפוינט מאומת

רשומה: `Checkpoint`

| שדה | משמעות |
|---|---|
| `origin` | שם היומן, למשל roll.eci.example/up |
| `size` | כמה שורות בעץ |
| `root` | ראש העץ |
| `signatures` | חתימת הוועדה וחתימות המשגיחים |

מה יכול להשתבש: הוועדה מפרסמת צ'קפוינט, ואף משגיח לא חותם כי משהו לא מסתדר. התשובה: בלי שלוש חתימות, הבוחר רואה "ממתין". אי אפשר להציג "מאומת" לבד.

טכנולוגיות: C2SP signed-note, Ed25519, HSM, שלוש חתימות לפחות

### פיצ'ר 6: התאמת פנקס ליומן

הפנקס שמתפרסם חייב להתאים לסכום כל השינויים ביומן, קלפי אחרי קלפי.

כמו קופה בסוף משמרת: מה שבמגירה חייב להיות מה שהיה בבוקר, ועוד כל הקבלות. פער אומר שמשהו לא נרשם.

מה בודקים? עם כל פרסום של פנקס, הוועדה מפרסמת גם גיבוב של כל קלפי. משגיח מריץ את כל השינויים ביומן מההתחלה, מגיע למצב של כל קלפי, ומשווה.

איך זה עובד:

1. הוועדה מפרסמת את הטיוטה, ולצידה BoothState לכל קלפי.
2. המשגיח מריץ את היומן מההתחלה ועד as_of_index.
3. הוא מחשב members_root לכל קלפי ומשווה.
4. קלפי שלא מתאימה נצבעת באדום בפומבי, עם מספר הרשומות החסרות.

נכנס: פנקס שפורסם ויומן · יוצא: התאמה, או קלפי אדומה

רשומה: `BoothState`

| שדה | משמעות |
|---|---|
| `booth` | מספר קלפי |
| `as_of_index` | עד איזו שורה ביומן |
| `members_root` | גיבוב של כל הרשומים בקלפי |
| `count` | כמה רשומים |

מה יכול להשתבש: הרשות מוחקת שמות ישירות בפנקס הסופי, בלי לשלוח ליומן. התשובה: הפנקס לא

מתאים לסכום היומן. הקלפי נצבעת, והחור גלוי.

טכנולוגיות: Merkle root לכל קלפי, PostgreSQL

### שלב 3: אצל הבוחר

מה רואה פריה, ומתי. בדיקה עצמית עם הוכחה, באתר, ב-SMS ובקיוסק. והתראה ביום השינוי, עם ערעור שכבר מולא.

### פיצ'ר 7: בדיקה עצמית

פריה שולחת את המספר שלה ומקבלת: מצב, היסטוריה, סיבה במילים, ותאריך אחרון לערעור.

כמו מעקב משלוח: מקלידים מספר, ורואים כל תחנה שהחבילה עברה. רק שכאן החבילה היא השם שלך.

מה פריה מקבלת? את השורות שלה ביומן, את הסיבה במילים ("עבר דירה") ובקוד (R-SHIFT), את התאריך האחרון לערעור, והוכחה של 27 גיבובים מול צ'קפוינט מאומת.

איך זה עובד:

- 1. פריה מקלידה מספר בוחר ותאריך לידה, באתר, ב-SMS או בקיוסק.
- 2. השירות מחשב את המזהה בתוך ה-HSM ומוצא את השורות שלה.
- 3. הוא מחזיר מצב, סיבה, מועד אחרון והוכחה.
- 4. האתר מאמת את ההוכחה בדפדפן. ב-SMS יוצא קוד קצר שאפשר להשוות לעיתון.

נכנס: מספר בוחר ותאריך לידה · יוצא: מצב, סיבה, מועד והוכחה

רשומה: `CheckResponse`

| שדה | משמעות |
|---|---|
| `status` | REGISTERED, REMOVED, RESTORED או PENDING |
| `reason` | קוד וסיבה במילים |
| `appeal_until` | תאריך אחרון לערעור |
| `proof` | 27 גיבובים |
| `checkpoint` | הצ'קפוינט המאומת |

מה יכול להשתבש: מישהו מנסה לבדוק אלף מספרים כדי לבנות רשימה של כל מי שנמחק בשכונה.
התשובה: חמש בדיקות ביום למספר, תאריך לידה כשדה שני, ואין רישום של מי חיפש מה.

טכנולוגיות: PWA, SMS gateway, הגבלת קצב, CDN

### פיצ'ר 8: התראה ופתיחת ערעור

מי שהשאיר טלפון מקבל **SMS** ביום שהשורה שלו משתנה, עם קישור לערעור שכבר מולא.

כמו התראה מהבנק על חיוב בכרטיס: לא מחכים לדף החשבון בסוף החודש. יודעים באותו יום, ויכולים לחסום.

למה ביום השינוי? כי ביום פרסום הטיוטה מתחיל השעון של הערעור. מי שמגלה שבועיים אחר כך, במקרה, מאבד שבועיים.

איך זה עובד:

- 1. שינוי בשורה של מי שנרשם להתראות מפעיל SMS.
- 2. ההודעה אומרת מה קרה, למה, ועד מתי אפשר לערער.
- 3. הקישור פותח טופס 6 (בקשת הכללה), עם קוד הסיבה ומזהה האירוע.
- 4. הערעור יוצא לבית הדין עם event_id, כך שהתיק מתחיל מעובדות.

נכנס: שינוי בשורה עם טלפון רשום · יוצא: SMS וערעור שמוכן לשליחה

רשומה: `Alert`

| משמעות | שדה |
|---|---|
| האירוע שהפעיל | `event_id` |
| מה השתנה | `status` |
| מועד אחרון | `appeal_until` |
| טופס 6 ממולא | `form_link` |

מה יכול להשתבש: ההתראה נשלחת למספר ישן, ופריה לא מקבלת אותה. התשובה: ההתראה היא תוספת. הבדיקה העצמית והקיוסק עובדים גם בלעדיה.

טכנולוגיות: SMS gateway, טופס 6 ממולא

### שלב 4: המשגיחים

מי מעיד, ומה רואים כולם. משגיחים עצמאיים שחותמים רק על יומן שרק גדל. ולוח פומבי של דפוסים, בלי אנשים.

### פיצ'ר 9: רשת משגיחים

עיתונים, ארגונים, מפלגות ואוניברסיטאות מריצים משגיח, ובודקים כל דקה שהיומן רק גדל.

כמו כמה עיתונים שמקבלים עותק של אותו מסמך רשמי ביום פרסומו: אם מחר מישהו יגיד שהוא נראה אחרת, כולם יכולים להוציא את העותק שלהם.

מה משגיח עושה? מושך כל צ'קפוינט, מבקש הוכחת עקביות מהצ'קפוינט הקודם (RFC 9162), וחותם רק אם היא תקפה. הוא לא צריך את השורות, רק ראשי עץ.

איך זה עובד:

- 1. גוף עצמאי נרשם כמשגיח ומריץ tlog-witness.
- 2. כל דקה הוא מושך צ'קפוינט ומבקש הוכחת עקביות.
- 3. אם ההוכחה תקפה, הוא חותם. אם לא, הוא מתריע בפומבי.
- 4. לפחות חמישה משגיחים, משלושה סוגי גופים, ושלוש חתימות לכל צ'קפוינט.

נכנס: צ'קפוינט חדש · יוצא: חתימה, או התראה

רשומה: `Witness`

| משמעות | שדה |
|---|---|
| שם המשגיח | `name` |
| עיתון, ארגון, מפלגה או אוניברסיטה | `kind` |
| גודל העץ האחרון שראה | `last_size` |
| ראש העץ האחרון שראה | `last_root` |

מה יכול להשתבש: לחץ על המשגיחים, או יומן שמראה לכל משגיח גרסה אחרת. התשובה: חמישה ומעלה, שלושה סוגים, ומשגיחים מחוץ למדינה. וגרסאות שונות נתפסות כשמשגיחים משווים ביניהם. (נבדק ב-POC.)

טכנולוגיות: tlog-witness, RFC 6962/9162, C2SP signed-note, שלוש חתימות לפחות

### פיצ'ר 10: נתונים מצרפיים

לכל קלפי ולכל קוד: כמה נוספו, הוסרו והוחזרו, ומתי. בלי שמות, ובלי מספרים קטנים מ-10.

כמו דוח תפוסה של בית חולים: כמה נכנסו לכל מחלקה, לא מי.

למה להשמיט מספרים קטנים? בקלפי עם שלושה נמחקים, "R-DEAD: 1" יכול לזהות אדם. מתחת ל-10 מוצג "פחות מ-10".

איך זה עובד:

1. כל שעה, הלוח מחשב לכל קלפי וקוד את מספר השינויים.
2. כל מספר קטן מ-10 מוחלף ב"פחות מ-10".
3. הלוח מציג גם את השינוי לאורך זמן, ומסמן קפיצות.
4. כל מספר מקושר לצ'קפוינט שממנו חושב.

נכנס: היומן · יוצא: לוח פומבי

רשומה: `Aggregate`

| שדה | משמעות |
|---|---|
| `booth` | קלפי |
| `code` | קוד סיבה |
| `count` | מספר, או "פחות מ-10" |
| `as_of` | צ'קפוינט |

מה יכול להשתבש: עיתונאי מחבר שני לוחות כדי לחשב מספר קטן שהושמט. התשובה: ההשמטה היא גם בסכומים: אי אפשר לחסר שני תאים כדי לקבל תא קטן.

טכנולוגיות: השמטת תאים קטנים, Grafana

## מסלול של שינוי אחד, מקצה לקצה

1. לחיצה: קצין רישום בלקנאו מסיר את פריה מקלפי 212, עם קוד R-SHIFT וכתובת חדשה ידועה. (כדי שכל מחיקה תגיד למה, עם ראיה.)
2. מזהה: המספר שלה הופך ל-92b8… בתוך ה-HSM, ונזרק. (כדי שהיומן לא יהיה רשימה של אנשים.)
3. עלה: השינוי נכנס כעלה 500,000 בעץ. (כדי שאי אפשר יהיה לשנות אותו אחר כך.)
4. חתימות: תוך דקה, הוועדה וחמישה משגיחים חותמים על ראש העץ. (כדי שלא צריך לסמוך על מי שמריץ את היומן.)
5. **SMS**: פריה מקבלת הודעה: הוסרת, עבר דירה, נותרו 30 יום לערעור. (כדי שהגילוי יהיה בזמן, לא במקרה.)
6. בדיקה: היא פותחת את האתר, מקבלת את השורה ו-27 גיבובים, וההוכחה תקפה. (כדי שהתשובה תהיה אותה תשובה שכולם רואים.)
7. התאמה: בפרסום הטיוטה, קלפי 212 ירוקה: הפנקס והיומן מסכימים. והלוח מראה כמה הוסרו, בלי שמות. (כדי ששום שינוי לא יעקוף את היומן.)

## הטכנולוגיות

| טכנולוגיה | מה זה | אצלנו | למה בחרנו |
|---|---|---|---|
| Debezium | כלי קוד פתוח שקורא כל שינוי שנכתב למסד נתונים (CDC), בלי לגעת בתוכנה שכותבת אותו. | קורא את טבלת השינויים של מערכת הפנקס הקיימת, ושולח כל שורה ליומן. | לא צריך לשנות את התוכנה של ועדת הבחירות כדי להתחבר אליה. |
| Apache Kafka | תור הודעות עמיד, שמחזיק אירועים גם אם מי שקורא אותם נופל. | כל שינוי בפנקס נכנס לתור, לפי מחוז, ונשמר 14 יום. | אם כותב היומן נופל, אף שינוי לא הולך לאיבוד. |
| בדיקת ראיה | החלטת תכנון: לכל קוד סיבה יש שדה ראיה חובה. | קצין שרושם R-DEAD חייב לצרף גיבוב של תעודת פטירה או דיווח רשמי. | זה מה שהופך את "אחר" לסיבה שאפשר לבדוק. |

| רשימה סגורה של קודים | החלטת תכנון: 11 קודים בלבד, ואין "אחר". | מערכת הפנקס לא יכולה לשלוח קוד שלא ברשימה. | הסל "נעדר, עבר או אחר" מתפרק לשלוש סיבות נפרדות. |
|---|---|---|---|
| HMAC-SHA256 | גיבוב עם מפתח סודי (RFC 2104). בלי המפתח אי אפשר לחשב אותו, וגם לא לנחש. | מספר הבוחר הופך למזהה מוצפן לפני שהוא נכנס ליומן. | גיבוב רגיל של מספר שאפשר לנחש לא מסתיר כלום. |
| HSM | קופסת חומרה שמחזיקה מפתחות סודיים, ועושה איתם חישובים בלי שהמפתח יוצא ממנה. | מחזיקה את מפתח ה-HMAC ואת מפתח החתימה של היומן. | גם פריצה מלאה לשרת לא מגלה את המפתח. |
| Tessera | הדור החדש של Trillian (Google): שרת יומן שקיפות ששומר את העץ כאריחים סטטיים. | מחזיק את כל השורות כעלים בעץ מרקל, ומגיש אריחים שאפשר לשים ב-CDN. | לא ממציאים קריפטוגרפיה: זה המבנה שמריץ את Certificate Transparency. |
| RFC 6962/9162 | התקן של Certificate Transparency: איך בונים את העץ, ואיך מוכיחים הכללה ועקביות. | קידומות 0x00 לעלה ו-0x01 לצומת, והוכחות לפי התקן. | כל כלי שכבר מדבר את התקן יכול לבדוק את היומן שלנו. |
| CDN | רשת שרתים שמגישה קבצים סטטיים מקרוב לכל משתמש. | האריחים של העץ והצ'קפוינטים יושבים בה. | בבוקר הטיוטה, מיליוני בדיקות לא נוגעות בשרתי הוועדה. |
| C2SP signed-note | פורמט פתוח לחתימה על ראש עץ, שמשגיחים יכולים להוסיף אליו חתימות. | כל דקה: גודל העץ, ראש העץ, וחתימות. | כל משגיח בעולם יודע לקרוא ולחתום על אותו פורמט. |
| Ed25519 | אלגוריתם חתימה מהיר וקצר. | הוועדה והמשגיחים חותמים בו על ראשי עץ. | חתימה של 64 בתים, שכל טלפון בודק. |
| שלוש חתימות לפחות | החלטת תכנון: צ'קפוינט "מאומת" רק עם שלוש חתימות משגיחים. | מתחת לשלוש, הבוחר רואה "ממתין". | משגיח אחד אפשר ללחוץ עליו. שלושה מגופים שונים, הרבה פחות. |
| Merkle root לכל קלפי | החלטת תכנון: עם כל פרסום של הפנקס, גיבוב של כל קלפי. | המשגיח מריץ את היומן מההתחלה ומשווה. | רשות שלא שלחה שינוי ליומן נתפסת, כי הפנקס לא מתאים לסכום. |
| PostgreSQL | בסיס נתונים פתוח ומוכר. | שומר את מצב הקלפיות לצורך ההתאמה. | כלי מוכר שכל צוות יודע להריץ. |
| PWA | אתר שמתנהג כמו אפליקציה, ועובד גם על טלפון זול. | פריה פותחת אותו, והוא בודק את ההוכחה בדפדפן. | לא צריך להתקין כלום. |
| SMS gateway | שירות ששולח ומקבל הודעות טקסט. | שולחים מספר בוחר, מקבלים סטטוס וקוד. | אמא של פריה בכפר בודקת בלי סמארטפון. |
| הגבלת קצב | החלטת תכנון: 5 בדיקות ביום למספר, ותאריך לידה כשדה שני. | שירות הבדיקה עונה רק לבעל המספר, ולאט. | בלי זה, מישהו מריץ את כל המספרים ובונה רשימה. |
| טופס 6 ממולא | החלטת תכנון: ההתראה מקשרת לבקשת הכללה שכבר מולאה. | קוד הסיבה ומזהה האירוע כבר בטופס. | הערעור מתחיל בלחיצה, לא בתור במשרד. |
| tlog-witness | תוכנת משגיח בקוד פתוח (C2SP, omniwitness). | כל עיתון או ארגון מריץ אותה על שרת קטן. | לא צריך לבנות משגיח מאפס. |
| השמטת תאים קטנים | החלטת תכנון: מספר קטן מ-10 מוצג כ"פחות | כל הנתונים המצרפיים עוברים דרכה. | בקלפי קטנה, מספר מדויק מזהה אנשים. |

| | | | |
|---|---|---|---|
| | | מ-10". | |
| Grafana | כלי לוחות נתונים מוכר. | מציג לכל קלפי וקוד כמה נוספו, הוסרו והוחזרו. | לא בונים ממשק לוחות מאפס. |

### החלטות שיכלו ללכת לצד השני

#### החלטה 1: מי מריץ את היומן?

- גוף עצמאי: בלי תלות בוועדה. אבל הוא לא יכול לכתוב לפנקס, וצריך לקבל ממנה הכול.
- הוועדה, עם משגיחים: רק היא כותבת. המשגיחים מאשרים.

בחרנו בוועדה, עם משגיחים. רק הוועדה יכולה לכתוב לפנקס, ולכן רק היא יכולה לשלוח ליומן בזמן. האמון לא בא ממי שמריץ, אלא ממי שמאשר. המחיר: תלות בזמינות של הוועדה.

#### החלטה 2: מזהה גלוי או במפתח?

- גיבוב רגיל: פשוט, וכל אחד מחפש לבד.
- **HMAC** במפתח, בתוך **HSM**: בלי המפתח, אין מילון.

בחרנו מפתח. יש רק כמה מאות מיליוני מספרים. גיבוב רגיל שלהם נפרץ בכמה שעות. המחיר: צריך שירות בדיקה, אי אפשר לחפש לבד.

#### החלטה 3: מתי נרשם שינוי?

- פעם ביום, בקובץ: פשוט. אבל יום שלם שבו שינוי לא נראה.
- לפני שהוא נכנס לתוקף: כל שינוי ביומן תוך דקה.

בחרנו לפני שהוא נכנס לתוקף. כדי שלא יהיה חלון שבו שינוי קיים בפנקס ולא ביומן. המחיר: עיכוב של עד דקה בכל פעולה.

#### החלטה 4: כמה חתימות משגיחים?

- אחת מספיקה: מהיר. אבל משגיח אחד אפשר ללחוץ עליו.
- שלוש מתוך חמש לפחות: קשה ללחוץ על כולם.

בחרנו שלוש מתוך חמש. שלושה גופים שונים, מסוגים שונים, שכולם חותמים על משהו שקרי, הוא תרחיש רחוק. המחיר: אם משגיחים נופלים, הבוחר רואה "ממתין".

#### החלטה 5: מה רואים כולם?

- כל השורות, עם קוד: שקיפות מלאה. וגם מפה של מי מת לפי רחוב.
- מצרפי, עם השמטה: דפוסים בלי אנשים.

בחרנו מצרפי. היומן עצמו ציבורי אבל בלי שמות, והמספרים מוצגים בלי לחשוף אף אחד. המחיר: פחות פירוט לחוקרים.

#### החלטה 6: להשאיר "אחר"?

- כן, לפעמים צריך: גמיש לקצינים.
- לא. 11 קודים, עם ראיה: כל מחיקה אומרת למה.

בחרנו בלי "אחר". "אחר" הוא בדיוק הסל שהתחיל את הבעיה. המחיר: עבודה נוספת לקצינים.

## מה השתנה מה-POC

| ב-POC | באפיון |
|---|---|
| HMAC עם מפתח בתוך התהליך | HMAC במפתח, בתוך HSM |
| קלפי ותאריך בכל שורה ציבורית | מצרפי ציבורי; פרטים מלאים רק בהוכחה האישית |
| חתימה מדומה ב-HMAC | Ed25519, ועוד שלוש חתימות משגיחים |
| אין בדיקה שהשינוי נשלח | התאמת פנקס ליומן, קלפי אחרי קלפי |
| משגיח אחד בדמיון | חמישה ומעלה, שלוש חתימות |

| | |
|---|---|
| פייתון בתהליך אחד | Tessera, אריחים ב-CDN, אתר, SMS וקיוסק |

### מה האפיון סגר, ומה נשאר פתוח

נסגר:

- שכתוב בשקט, שתי גרסאות, שינוי שלא נשלח, בוחר שלא יודע, וקוד סיבה סתום.
- הליבה נשענת על תקן Certificate Transparency ועל קוד שכבר רץ בייצור.

נשאר פתוח:

- היומן מוכיח מה נרשם, לא שמה שנרשם נכון. אם קצין רושם R-DEAD על אדם חי, היומן ישמור את זה בנאמנות.
- מה שמשתנה: האדם החי יכול לראות את זה, בזמן, ולערער. ומי יקשיב לערעור בזמן? את זה היומן לא פותר.

יומן שרואה הכול, ולא מתקן כלום. האם זה מספיק?